Evidencias de seguridad backend

Lenguaje de Programación II | Sesión 10 | PharmaBackend

Estudiante: Caleb David Asmat Briceño
Código: 202510208
Rama: feature/seguridad-jwt
Repositorio: https://github.com/ADavid2507/PharmaDB.git

Preparación en Postman

```
if (pm.response.code === 200) {
  pm.collectionVariables.set("token", pm.response.json().token);
}
```

Credenciales de desarrollo

`admin / Admin2026*`

`vendedor / Vendedor2026*`

`almacen / Almacen2026*`

`supervisor / Supervisor2026*`

`inactivo / Inactivo2026*`

Prueba 01 Health público

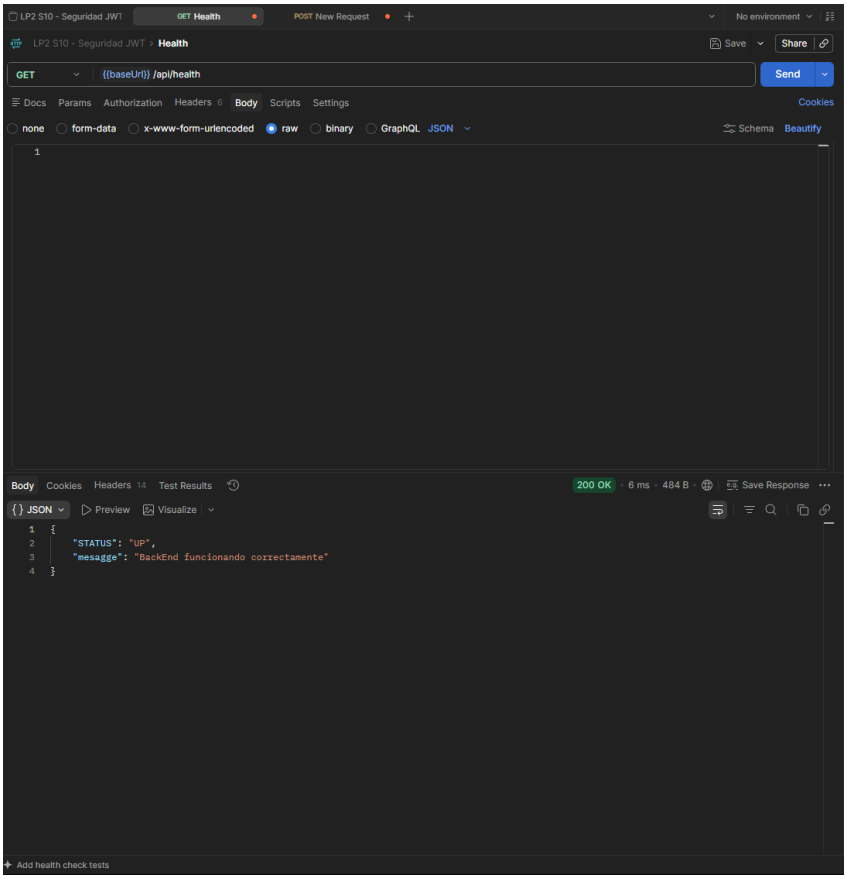
Usuario o condición: Sin token

Petición: GET /api/health
Base: {{baseUrl}} = http://localhost:8080

Resultado esperado: 200; ruta pública.

Resultado obtenido: 200 OK. El endpoint health devolvió STATUS UP y el mensaje BackEnd funcionando correctamente.

Estado: Cumple
Observaciones: Ninguna.



Prueba 02 Productos sin sesión

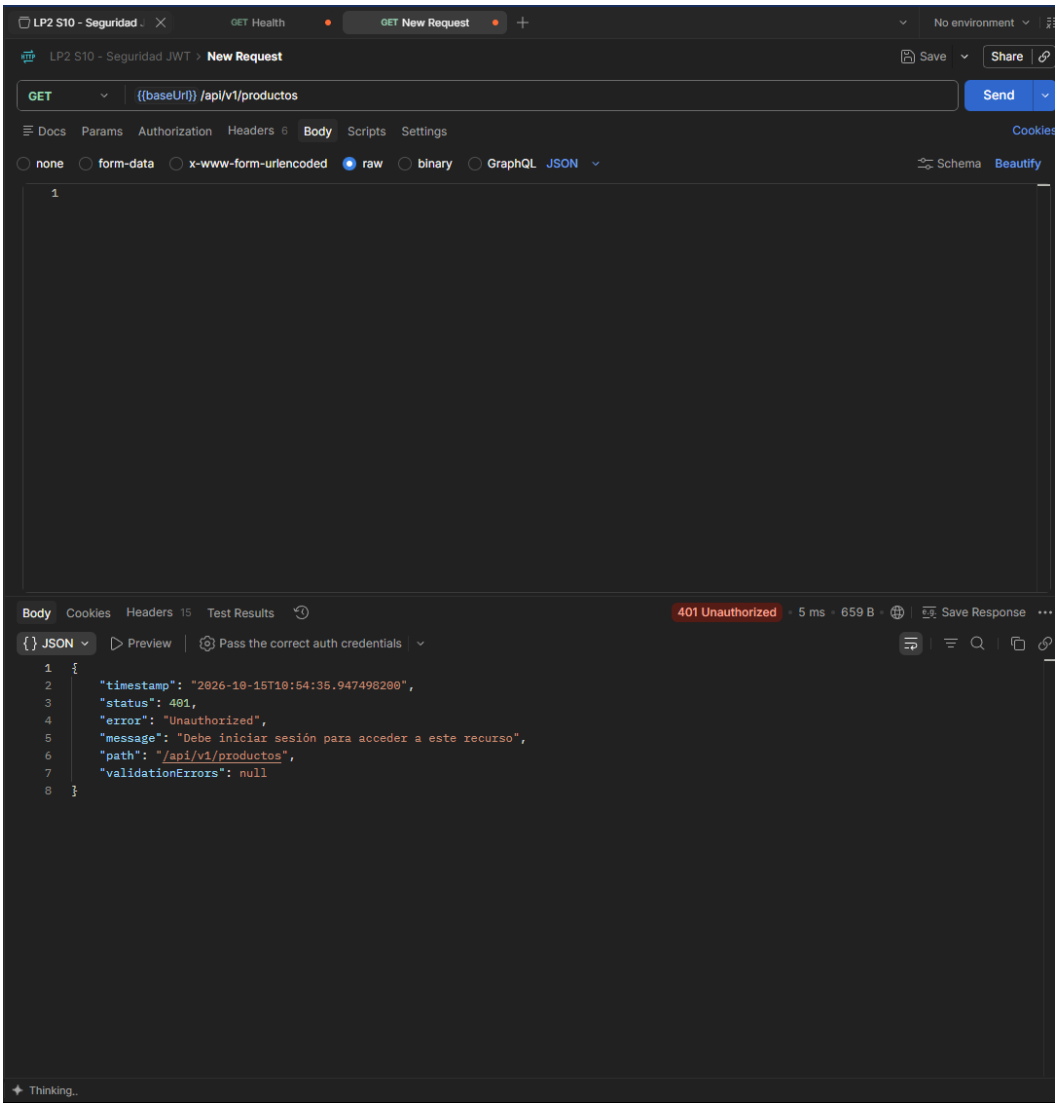
Usuario o condición: Sin token

Petición: GET /api/v1/productos
Base: {{baseUrl}} = http://localhost:8080

Resultado esperado: 401; Debe iniciar sesión para acceder a este recurso.

Resultado obtenido: 401 Unauthorized. La API respondió Debe iniciar sesión para acceder a este recurso.

Estado: Cumple
Observaciones: Ninguna.



Prueba 03 Contraseña incorrecta

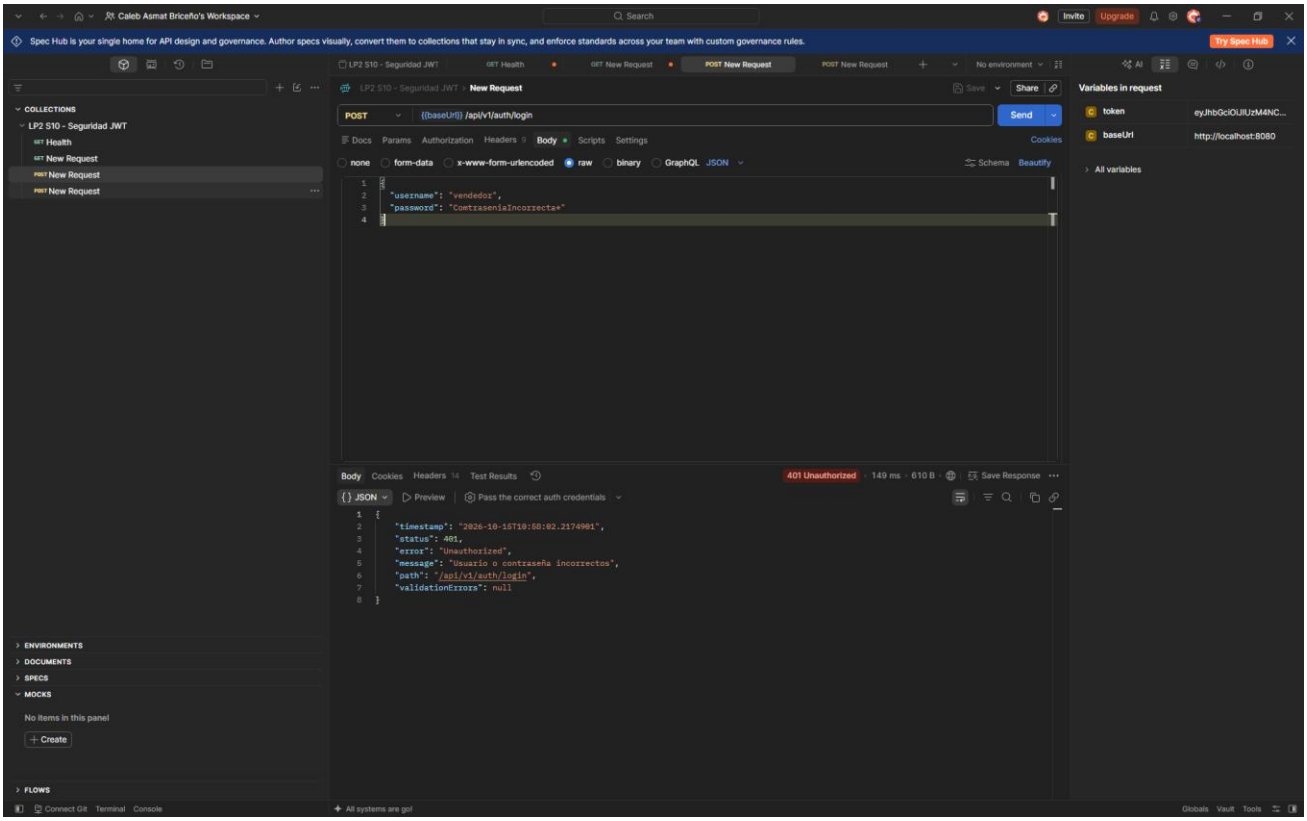
Usuario o condición: Sin token

Petición: POST /api/v1/auth/login
Base: {{baseUrl}} = http://localhost:8080

Resultado esperado: 401; Usuario o contraseña incorrectos.

Resultado obtenido: 401 Unauthorized. El login de vendedor con contraseña incorrecta devolvió Usuario o contraseña incorrectos.

Estado: Cumple
Observaciones: La captura utiliza vendedor con contraseña incorrecta; se comprueba el mismo rechazo de autenticación previsto.



Prueba 04 Cuenta inactiva

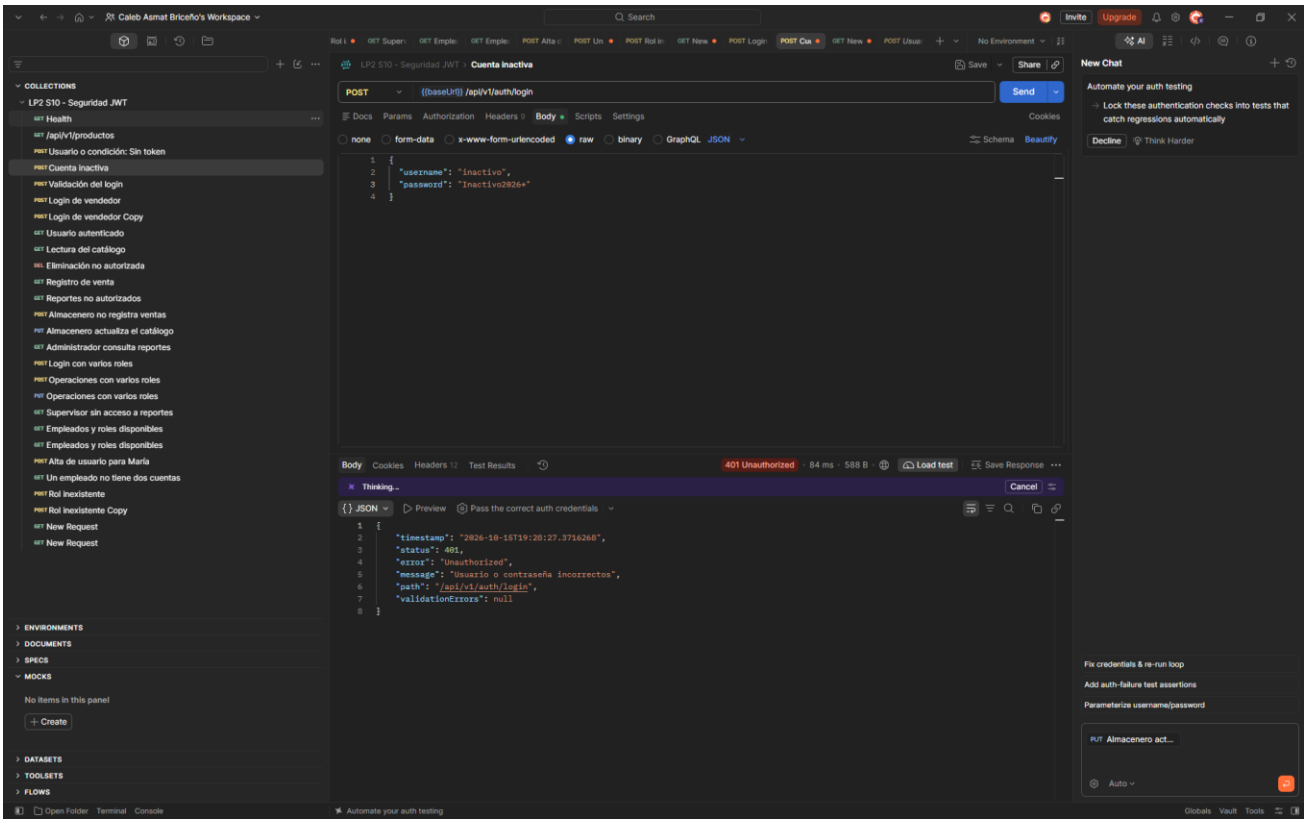
Usuario o condición: Sin token

Petición: POST /api/v1/auth/login
Base: {{baseUrl}} = http://localhost:8080

Resultado esperado: 401; Usuario o contraseña incorrectos.

Resultado obtenido: 401 Unauthorized. Usuario o contraseña incorrectos.

Estado: Cumple
Observaciones: Ninguna



Prueba 05 Validación del login

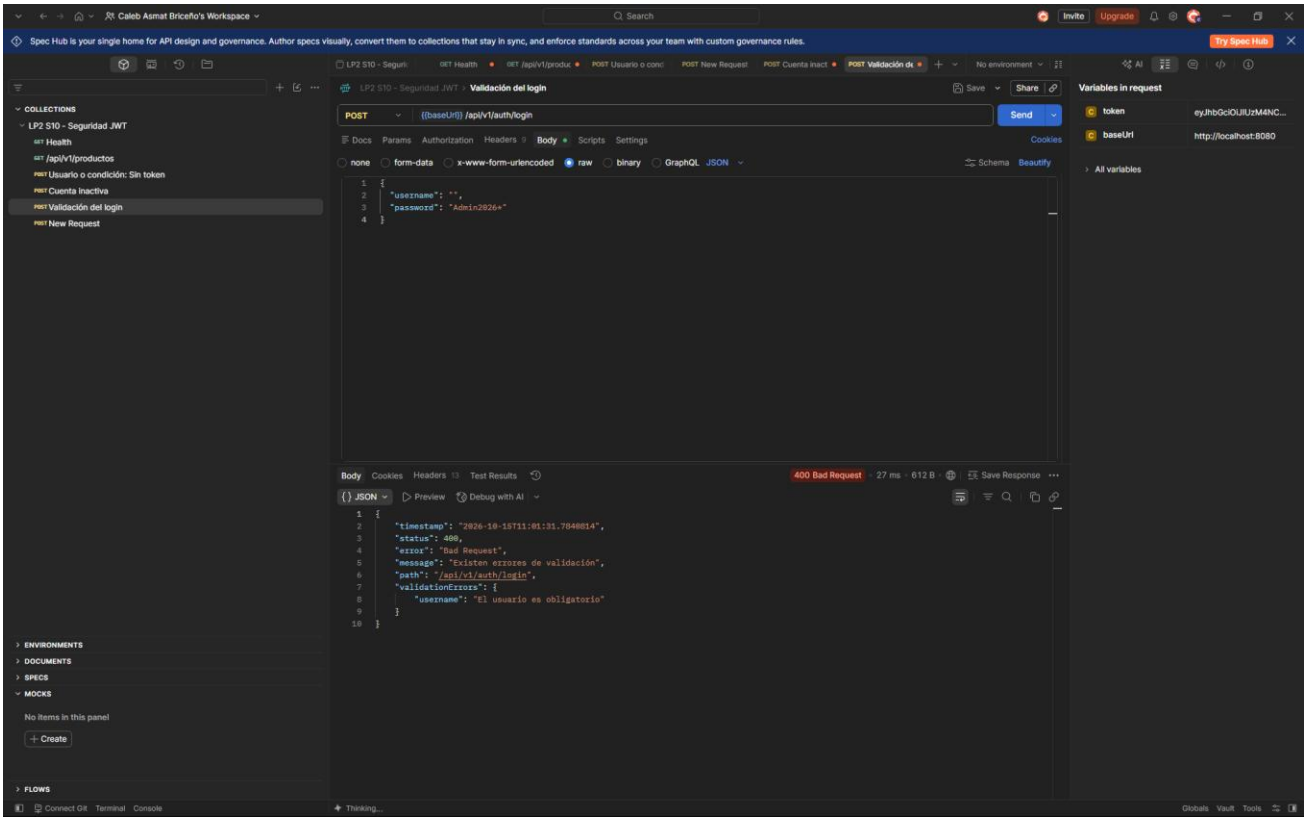
Usuario o condición: Sin token

Petición: POST /api/v1/auth/login
Base: {{baseUrl}} = http://localhost:8080

Resultado esperado: 400; validationErrors contiene username.

Resultado obtenido: 400 Bad Request. Se devolvió validationErrors.username con el mensaje El usuario es obligatorio.

Estado: Cumple
Observaciones: Ninguna.



Prueba 06 Login de vendedor

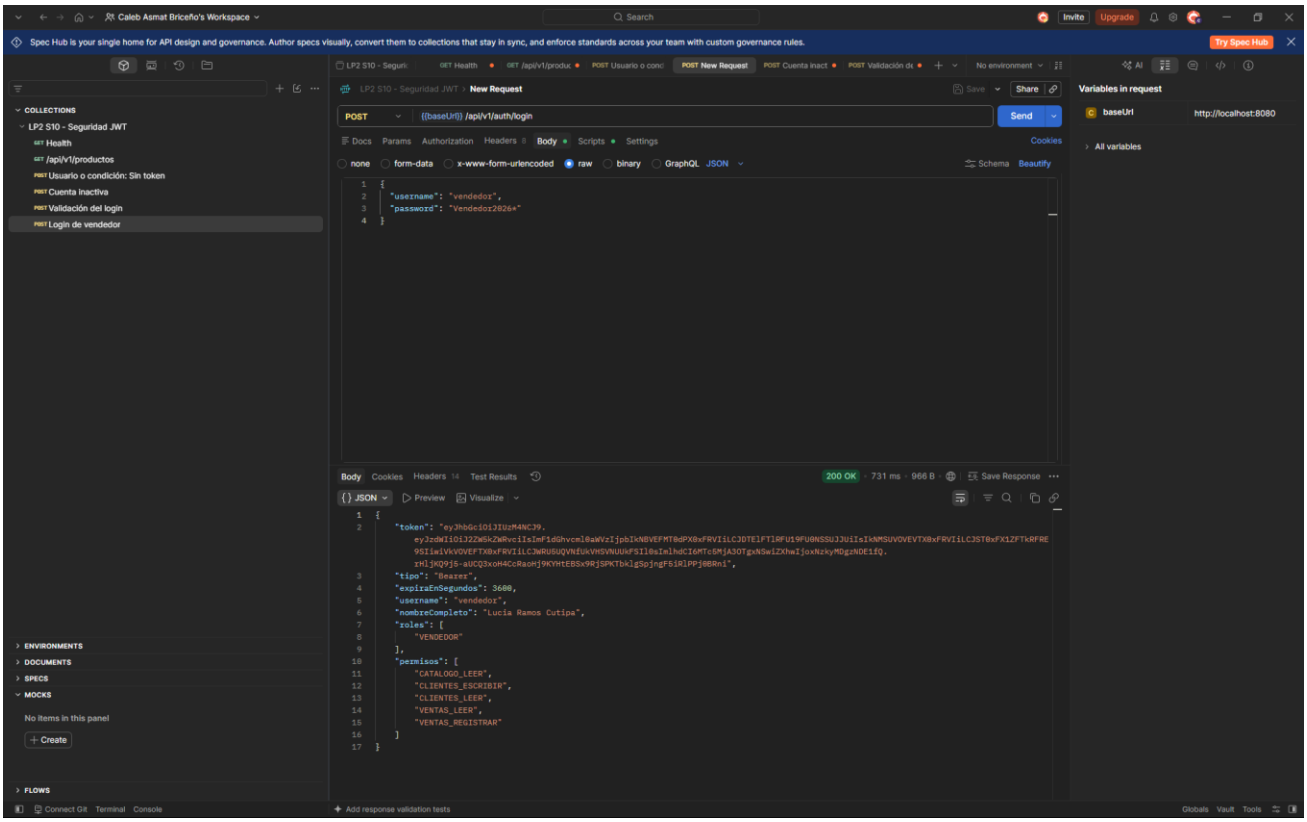
Usuario o condición: Sin token

Petición: POST /api/v1/auth/login
Base: {{baseUrl}} = http://localhost:8080

Resultado esperado: 200; token, tipo Bearer, duración 3600, rol VENDEDOR y sus permisos.

Resultado obtenido: 200 OK. Se obtuvo un token Bearer con duración de 3600 segundos, rol VENDEDOR y sus cinco permisos.

Estado: Cumple
Observaciones: Ninguna.



Prueba 07 Contenido del token

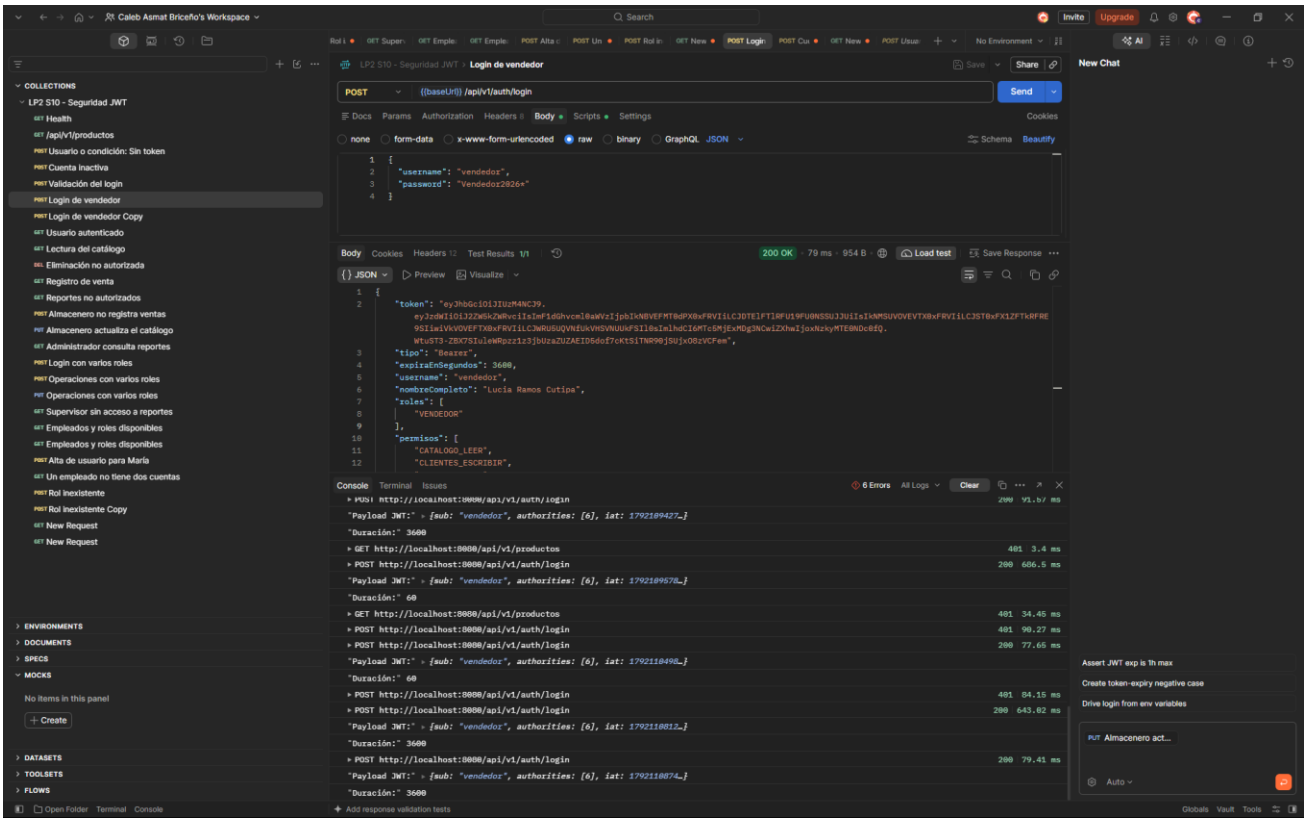
Usuario o condición: vendedor

Petición: Decodificación del payload del JWT
Base: {{baseUrl}} = http://localhost:8080

Resultado esperado: sub = vendedor; authorities contiene roles y permisos; iat y exp; exp - iat = 3600.

Resultado obtenido: 200 OK en el login de vendedor. La respuesta informa 3600 segundos y Postman muestra Test Results 1/1.

Estado: Cumple
Observaciones: Ninguna.



Prueba 08 Usuario autenticado

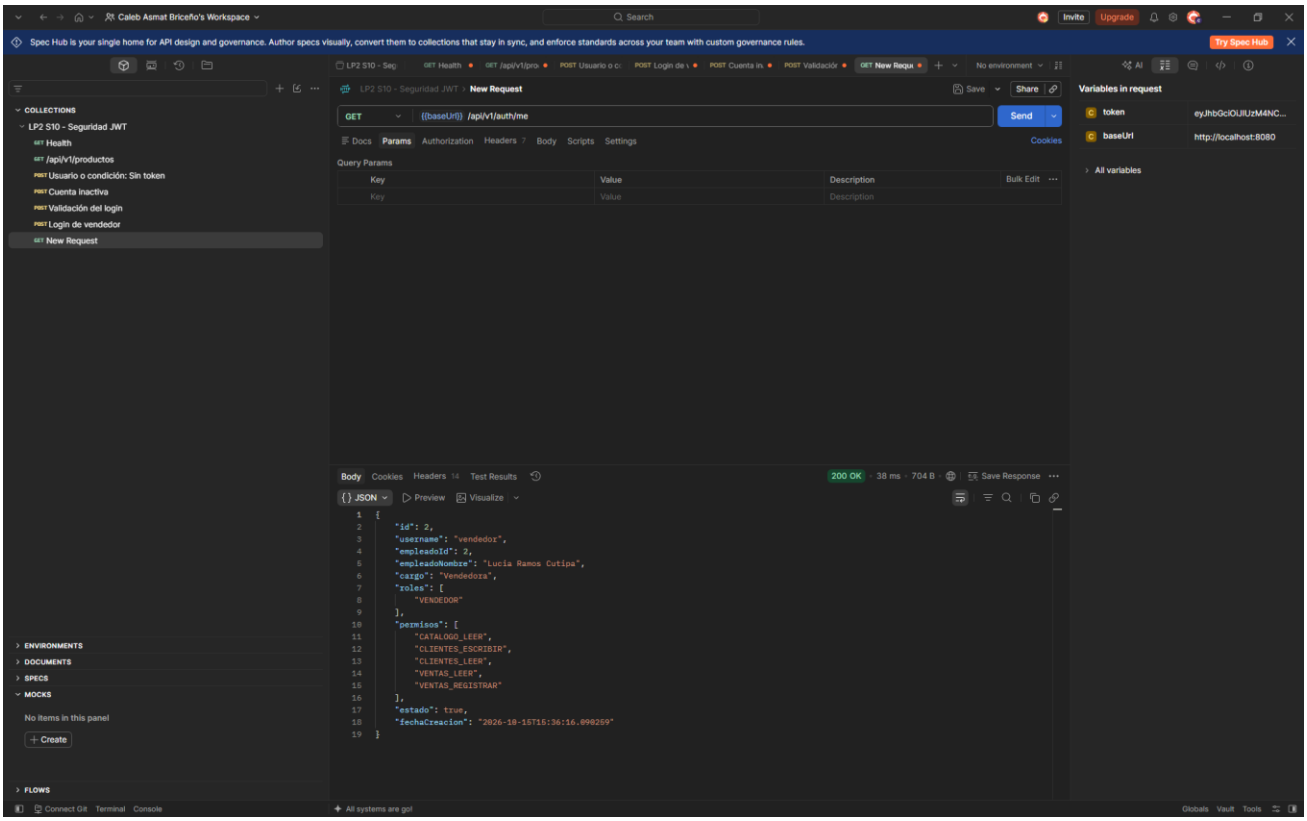
Usuario o condición: vendedor

Petición: GET /api/v1/auth/me
Base: {{baseUrl}} = http://localhost:8080

Resultado esperado: 200; datos del usuario sin contraseña ni hash.

Resultado obtenido: 200 OK. Se obtuvieron los datos del usuario vendedor, sus roles y permisos sin contraseña ni hash.

Estado: Cumple
Observaciones: Ninguna.



Prueba 09 Lectura del catálogo

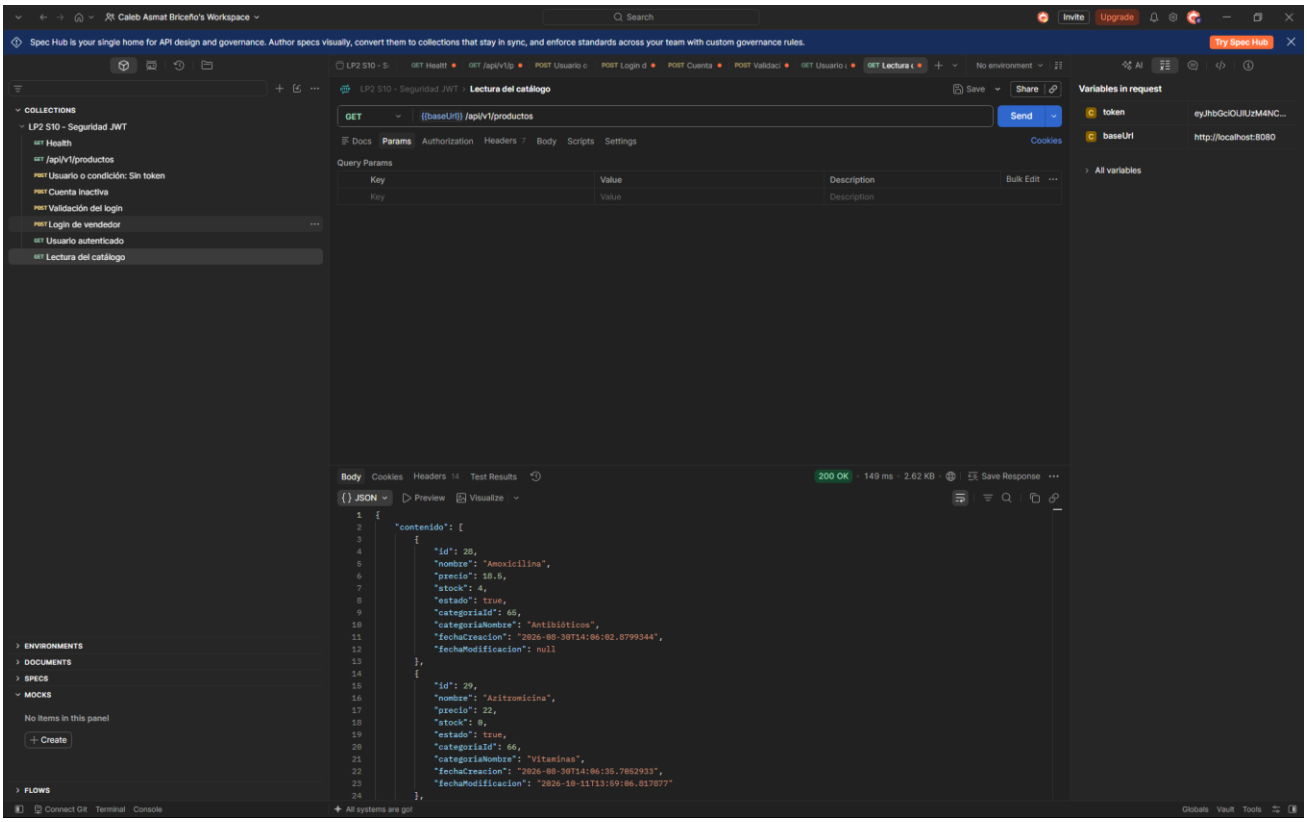
Usuario o condición: vendedor

Petición: GET /api/v1/productos
Base: {{baseUrl}} = http://localhost:8080

Resultado esperado: 200; listado de productos.

Resultado obtenido: 200 OK. Se obtuvo el listado paginado de productos con sus datos de catálogo.

Estado: Cumple
Observaciones: Ninguna.



Prueba 10 Eliminación no autorizada

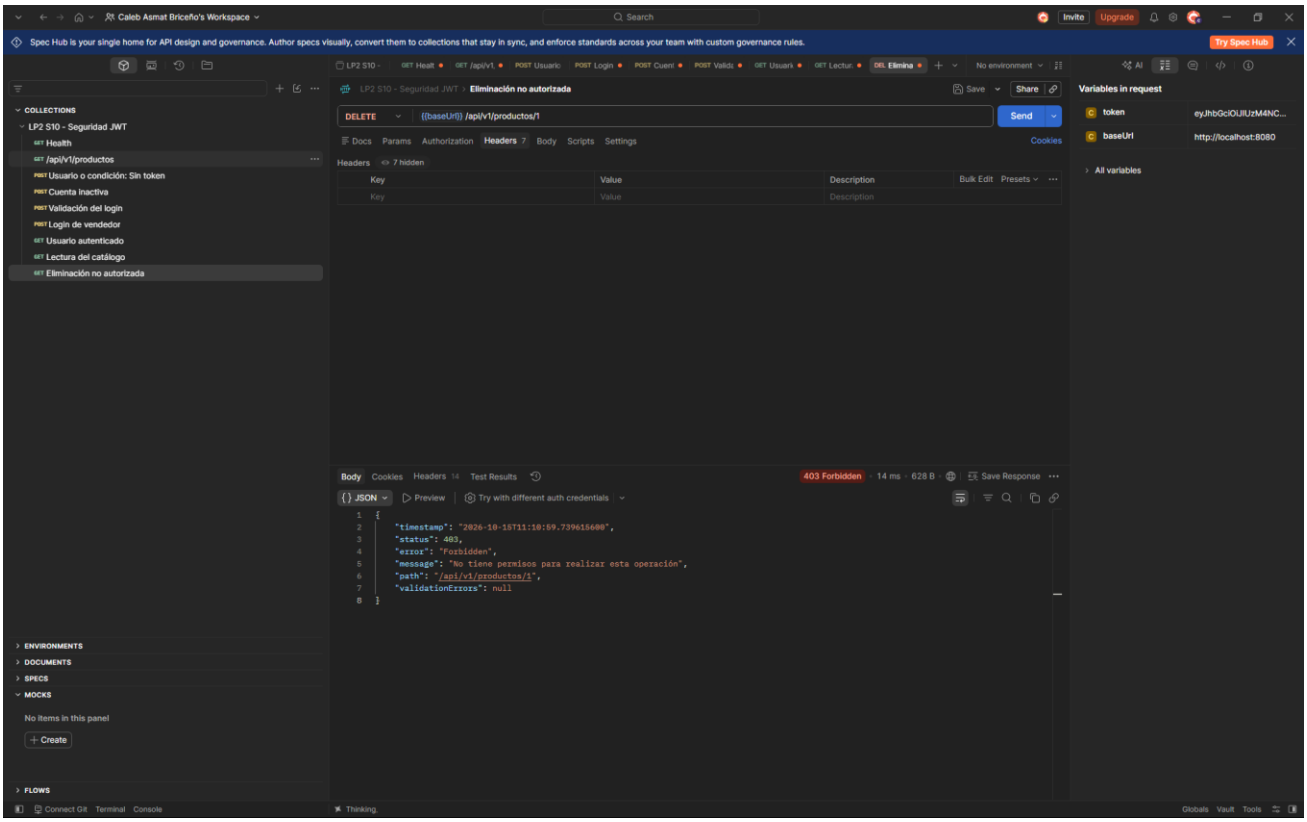
Usuario o condición: vendedor

Petición: DELETE /api/v1/productos/1
Base: {{baseUrl}} = http://localhost:8080

Resultado esperado: 403; No tiene permisos para realizar esta operación.

Resultado obtenido: 403 Forbidden. La API rechazó DELETE /api/v1/productos/1 con el mensaje No tiene permisos para realizar esta operación.

Estado: Cumple
Observaciones: Ninguna.



Prueba 11 Registro de venta

Usuario o condición: vendedor

Petición: POST /api/v1/ventas
Base: {{baseUrl}} = http://localhost:8080

Resultado esperado: 201; venta creada.

Resultado obtenido: 200 OK.

Observaciones:

Prueba 12 Reportes no autorizados

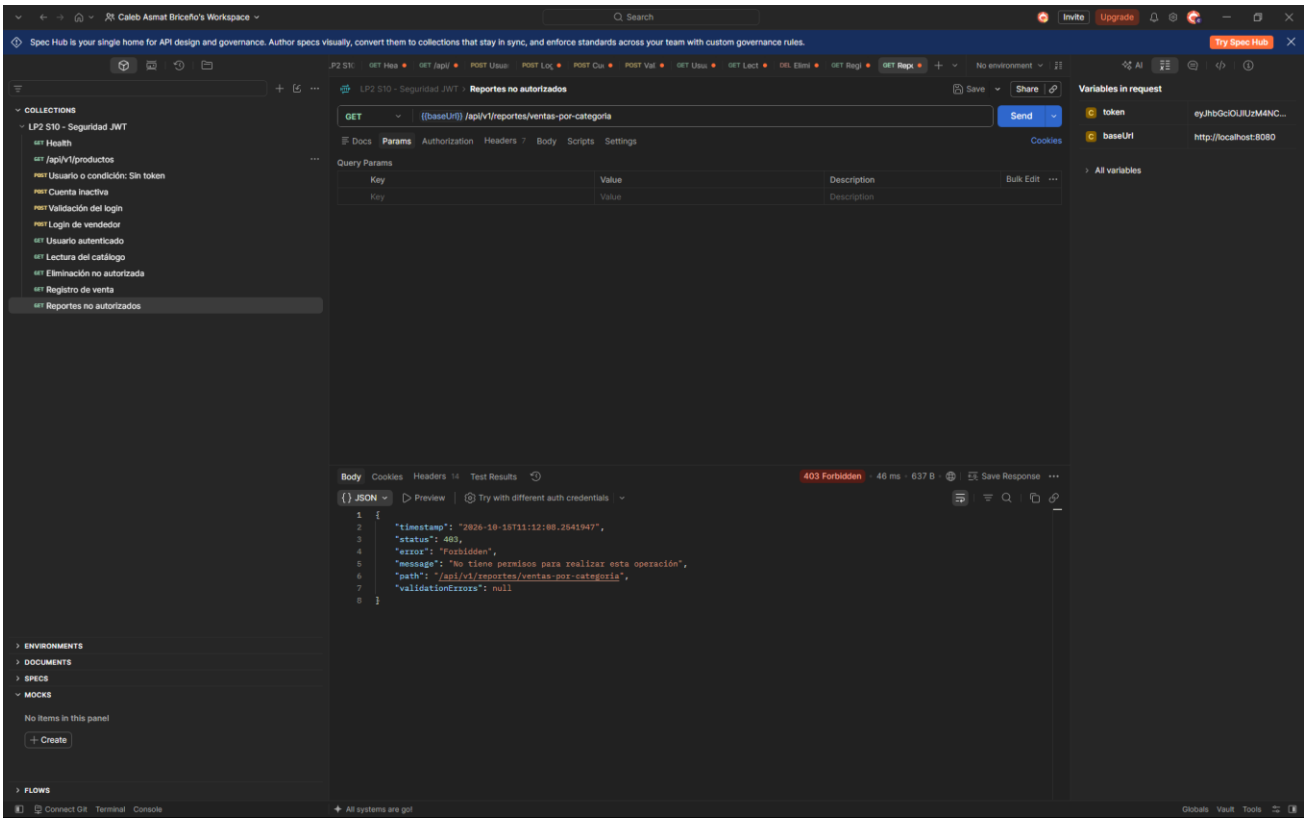
Usuario o condición: vendedor

Petición: GET /api/v1/reportes/ventas-por-categoria
Base: {{baseUrl}} = http://localhost:8080

Resultado esperado: 403; acceso denegado por permiso REPORTES_VER.

Resultado obtenido: 403 Forbidden. Se rechazó la consulta del reporte con el mensaje No tiene permisos para realizar esta operación.

Estado: Cumple
Observaciones: Ninguna.



Prueba 13 Almacenero no registra ventas

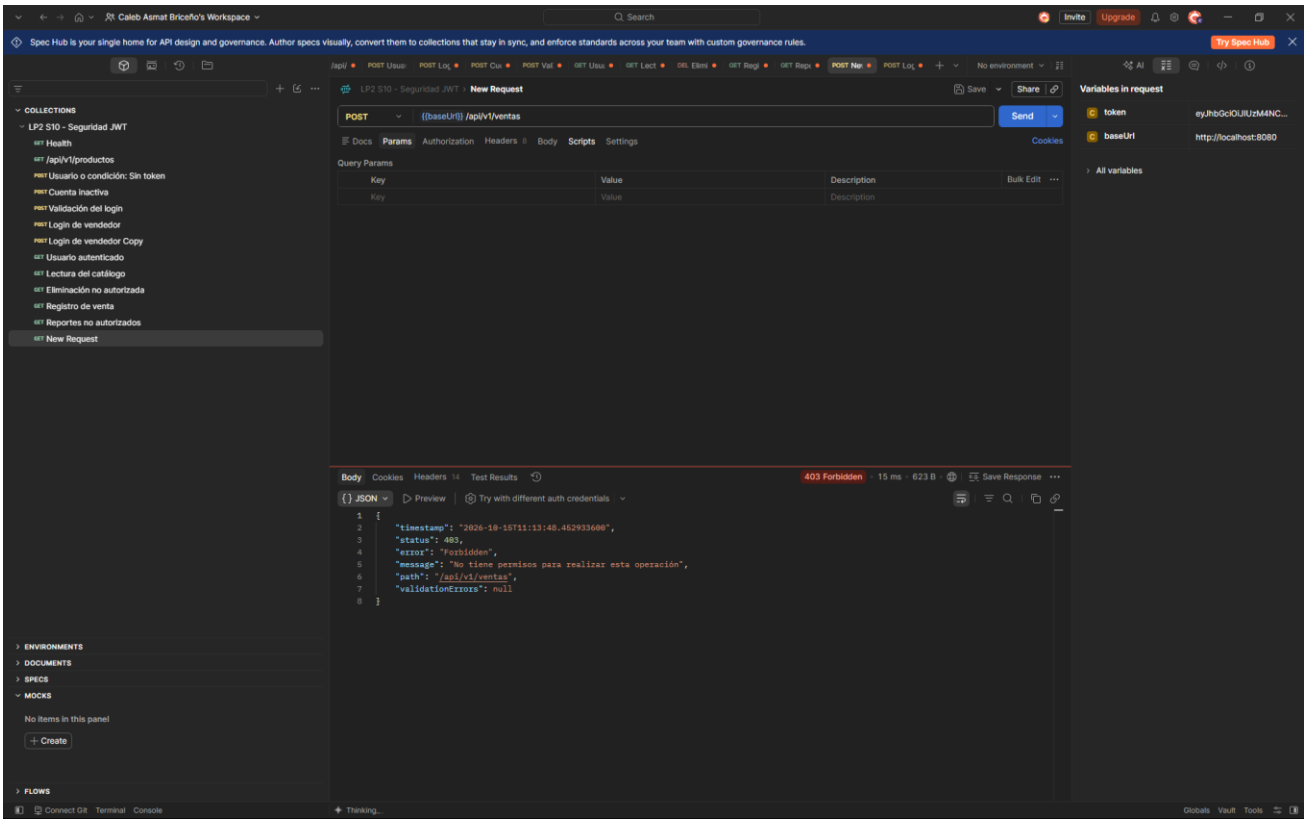
Usuario o condición: almacen

Petición: POST /api/v1/ventas
Base: {{baseUrl}} = http://localhost:8080

Resultado esperado: 403; operación no autorizada.

Resultado obtenido: 403 Forbidden. Se rechazó POST /api/v1/ventas con el mensaje No tiene permisos para realizar esta operación.

Estado: Cumple
Observaciones: Ninguna.



Prueba 14 Almacenero actualiza el catálogo

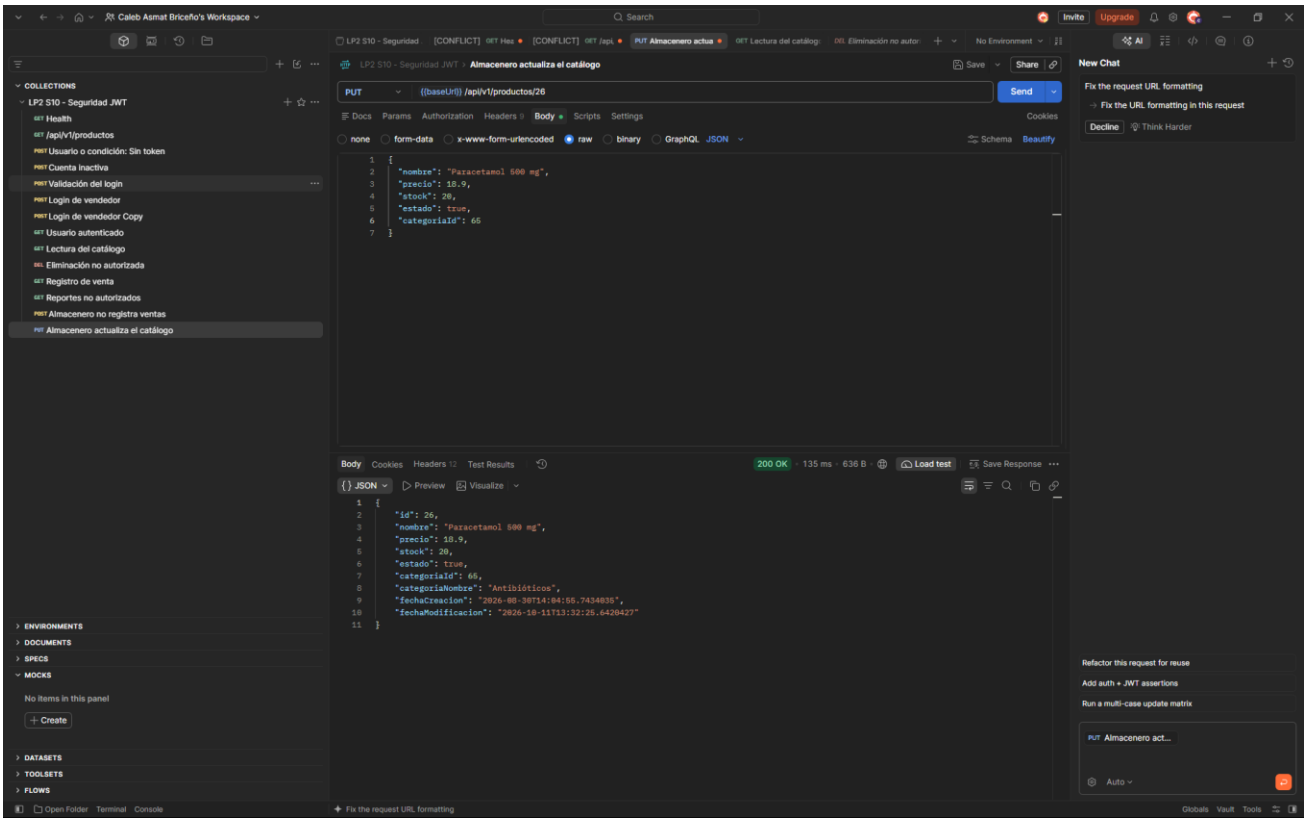
Usuario o condición: almacen

Petición: PUT /api/v1/productos/{id}
Base: {{baseUrl}} = http://localhost:8080

Resultado esperado: 200; producto actualizado.

Resultado obtenido: 200 OK. Se actualizó el producto 26, Paracetamol 500 mg, con precio 18.9, stock 20 y categoría 65.

Estado: Cumple
Observaciones: Ninguna.



Prueba 15 Administrador consulta reportes

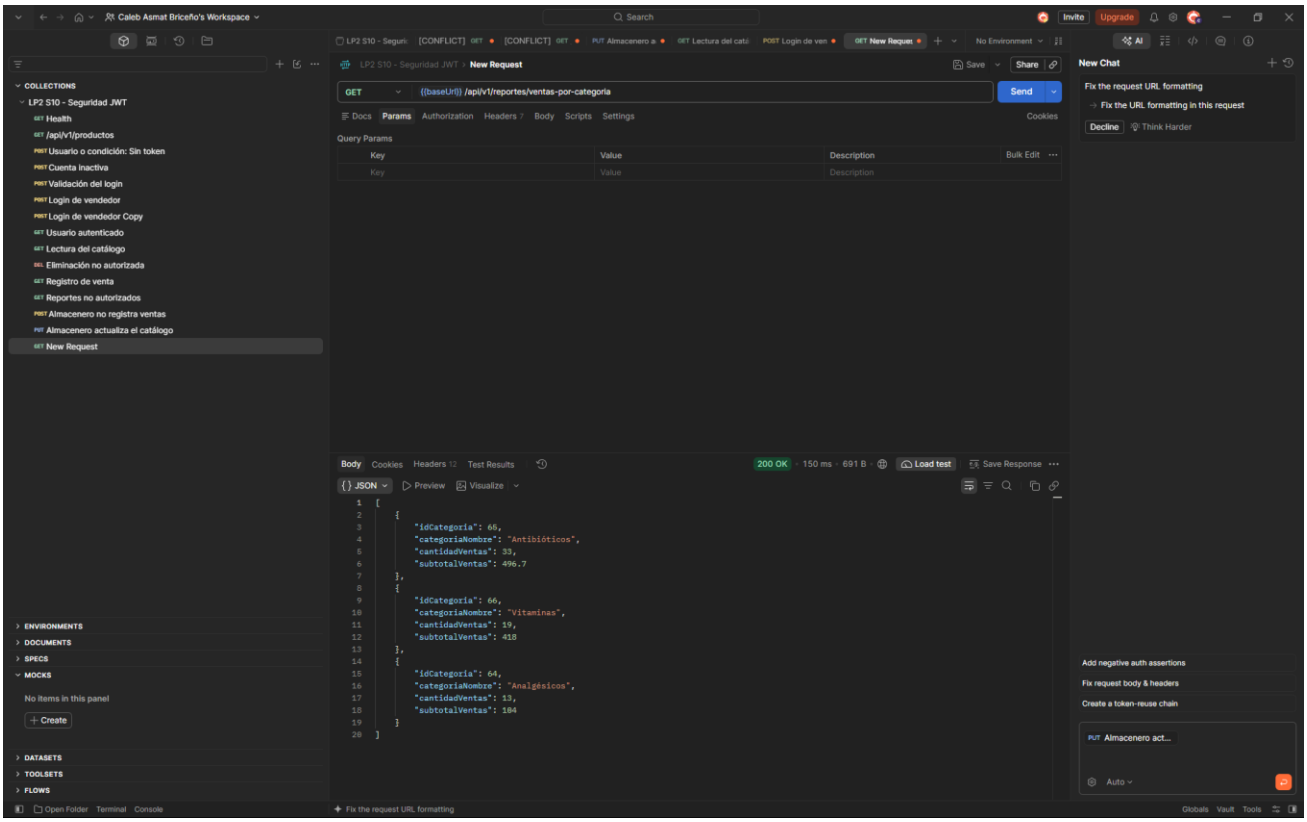
Usuario o condición: admin

Petición: GET /api/v1/reportes/ventas-por-categoria
Base: {{baseUrl}} = http://localhost:8080

Resultado esperado: 200; datos del reporte.

Resultado obtenido: 200 OK. Se obtuvo el reporte de ventas por categoría con cantidades y subtotales.

Estado: Cumple
Observaciones: Ninguna.



Prueba 16 Login con varios roles

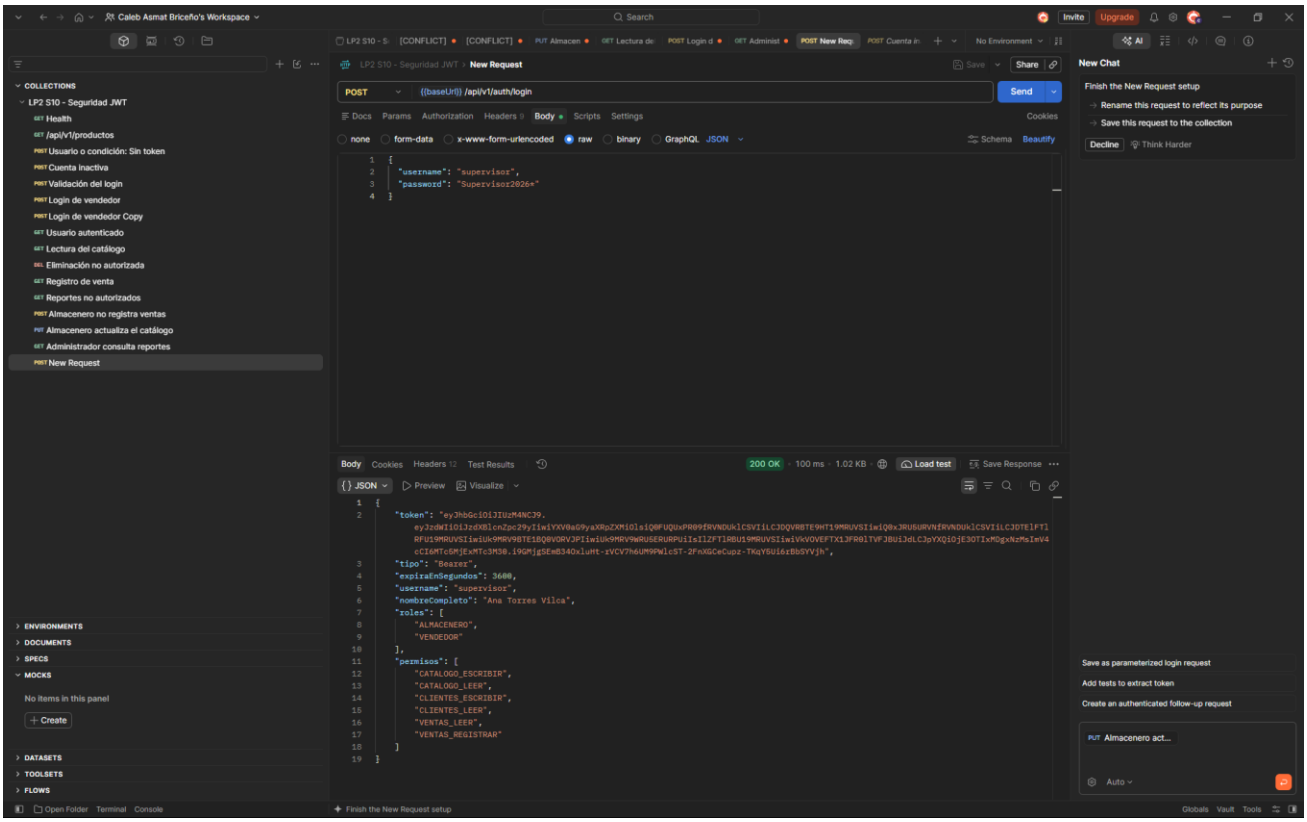
Usuario o condición: Sin token

Petición: POST /api/v1/auth/login
Base: {{baseUrl}} = http://localhost:8080

Resultado esperado: 200; roles ALMACENERO y VENDEDOR y unión de permisos sin REPORTES_VER.

Resultado obtenido: 200 OK. El login de supervisor devolvió los roles ALMACENERO y VENDEDOR y la unión de sus seis permisos, sin REPORTES_VER.

Estado: Cumple
Observaciones: Ninguna.



Prueba 17 Operaciones con varios roles

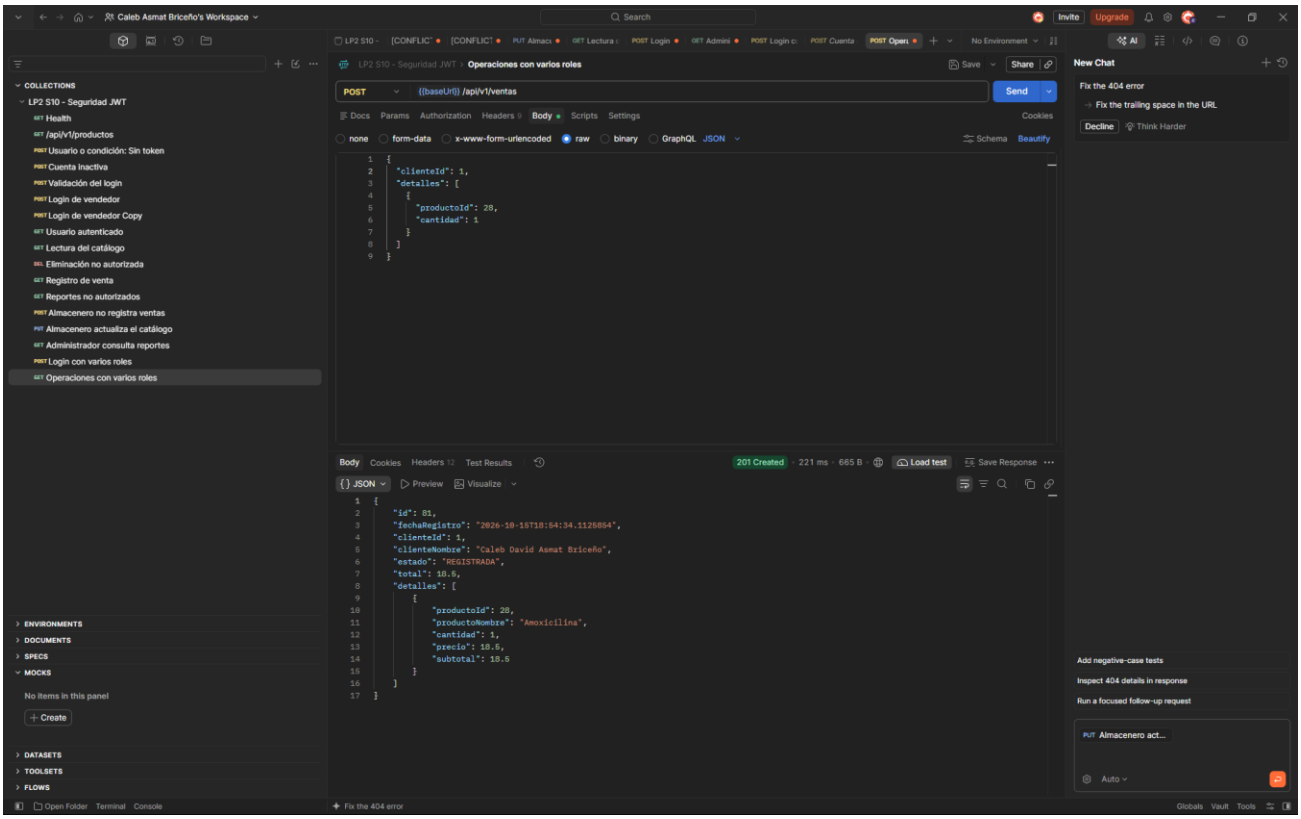
Usuario o condición: supervisor

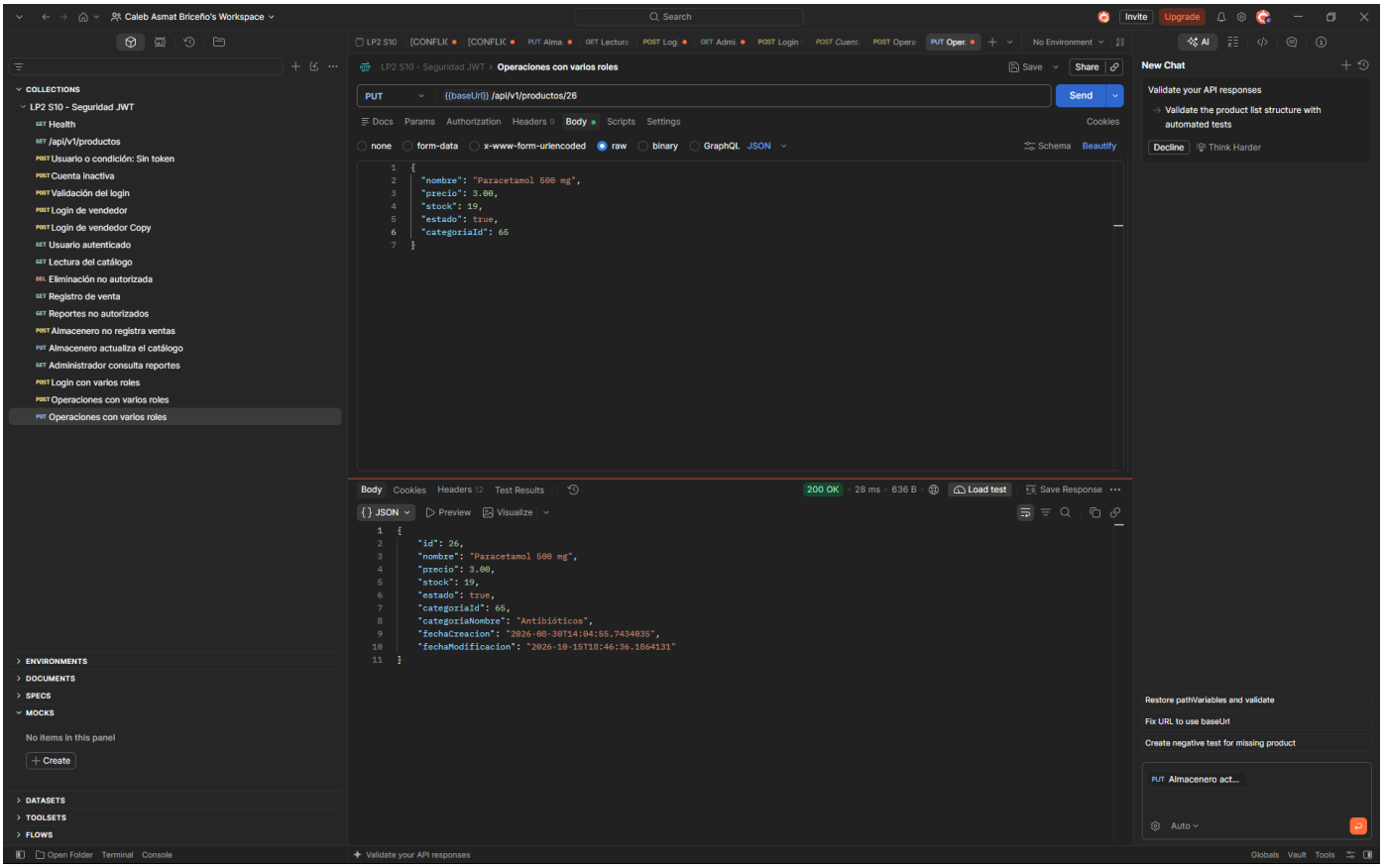
Petición: POST /api/v1/ventas y PUT /api/v1/productos/{id}
Base: {{baseUrl}} = http://localhost:8080

Resultado esperado: 201 en la venta y 200 en la actualización.

Resultado obtenido: 201 Created al registrar la venta 81 para el cliente 1, con una unidad del producto 28 y total 18.5. Además, 200 OK al actualizar el producto 26 a precio 3.00 y stock 19.

Estado: Cumple
Observaciones: Ninguna.




Caleb Asmat Briceño's Workspace
Search
Invite
Upgrade
COLLECTIONS
LP2 S10 - Seguridad JWT
GET Health
GET /api/v1/productos
POST Usuario o condición: Sin token
POST Cuenta inactiva
POST Validación del login
POST Login de vendedor
POST Login de vendedor Copy
GET Usuario autenticado
GET Lectura del catálogo
DEL Eliminación no autorizada
GET Registro de venta
GET Reportes no autorizados
POST Almacenero no registra ventas
PUT Almacenero actualiza el catálogo
GET Administrador consulta reportes
POST Login con varios roles
POST Operaciones con varios roles
PUT Operaciones con varios roles
ENVIRONMENTS
DOCUMENTS
SPECS
MOCKS
No items in this panel
Create
DATASETS
TOOLSETS
FLOWS
LP2 S10 - Seguridad JWT › Operaciones con varios roles
Save
Share
PUT
{{baseUrl}} /api/v1/productos/26
Send
Docs
Params
Authorization
Headers 8
Body
Scripts
Settings
Cookies
none
form-data
x-www-form-urlencoded
raw
binary
GraphQL
JSON
Schema
Beautify
{
"nombre": "Paracetamol 500 mg",
"precio": 3.00,
"stock": 19,
"estado": true,
"categoriaId": 65
}
Body
Cookies
Headers 12
Test Results
200 OK
28 ms
636 B
Load test
Save Response
JSON
Preview
Visualize
{
"id": 26,
"nombre": "Paracetamol 500 mg",
"precio": 3.00,
"stock": 19,
"estado": true,
"categoriaId": 65,
"categoriaNombre": "Antibióticos",
"fechaCreacion": "2026-08-30T14:04:55.7434035",
"fechaModificacion": "2026-10-15T18:46:36.1864131"
}
New Chat
Validate your API responses
Validate the product list structure with automated tests
Decline
Think Harder
Restore pathVariables and validate
Fix URL to use baseUrl
Create negative test for missing product
PUT Almacenero act...
Auto
Open Folder
Terminal
Console
Validate your API responses
Globals
Vault
Tools

Prueba 18 Supervisor sin acceso a reportes

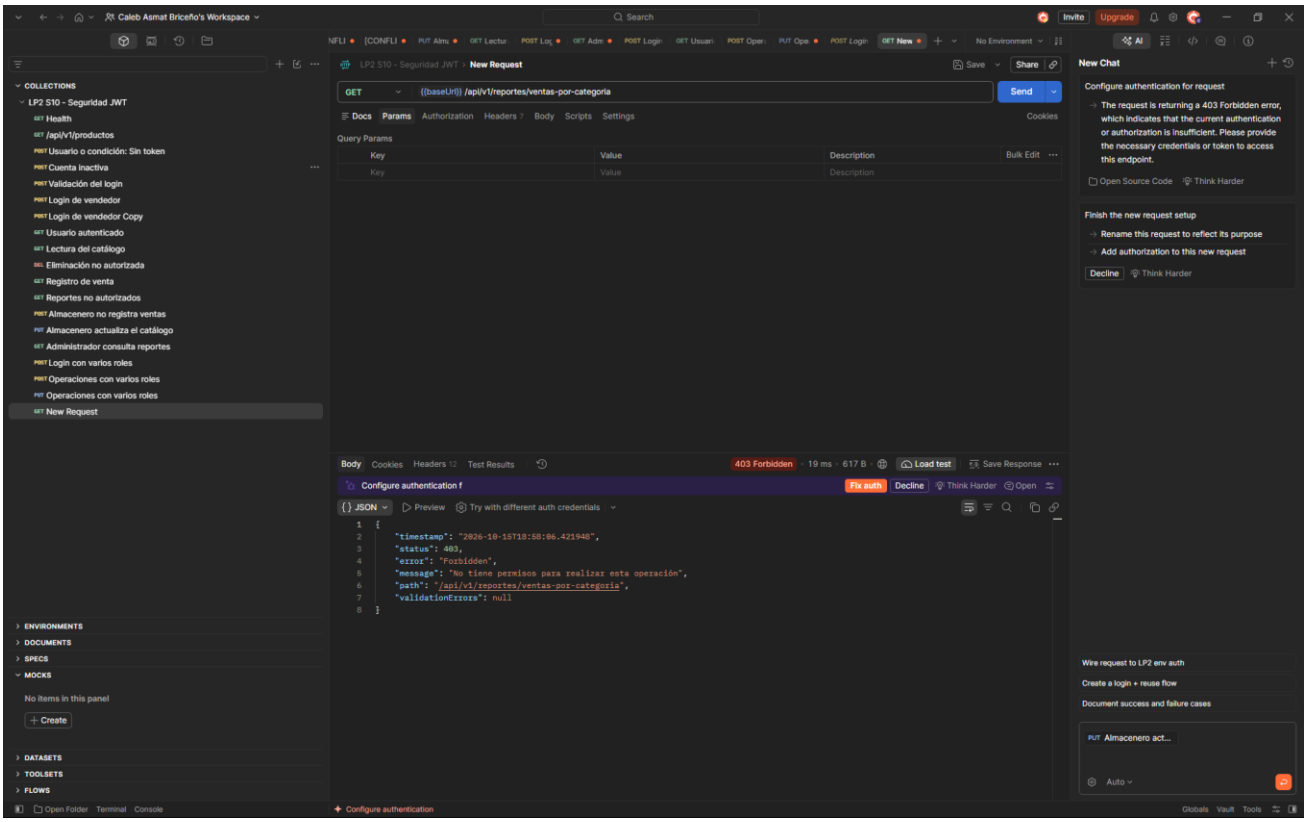
Usuario o condición: supervisor

Petición: GET /api/v1/reportes/ventas-por-categoria
Base: {{baseUrl}} = http://localhost:8080

Resultado esperado: 403; ninguno de sus roles otorga REPORTES_VER.

Resultado obtenido: 403 Forbidden. Se rechazó el acceso del supervisor a reportes con el mensaje No tiene permisos para realizar esta operación.

Estado: Cumple
Observaciones: Ninguna.



Prueba 19 Empleados y roles disponibles

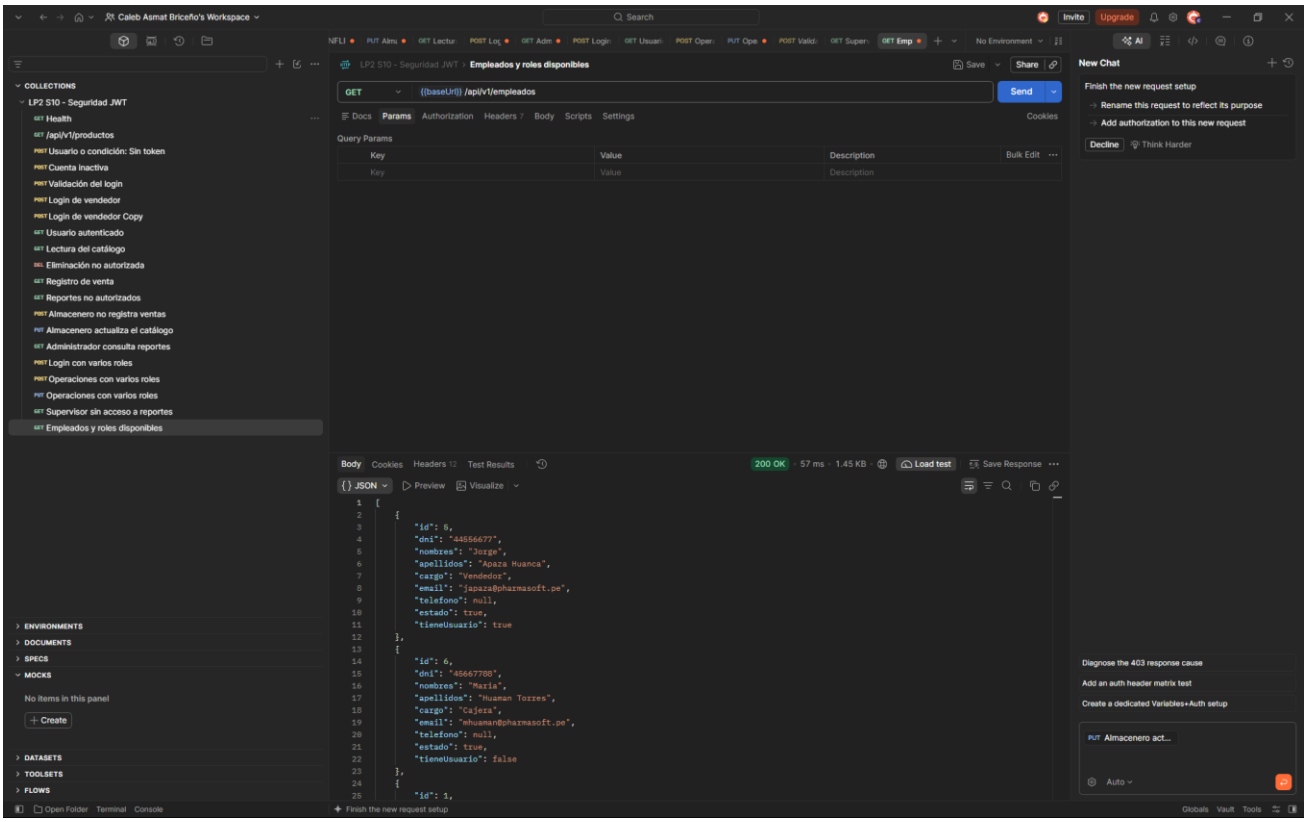
Usuario o condición: admin

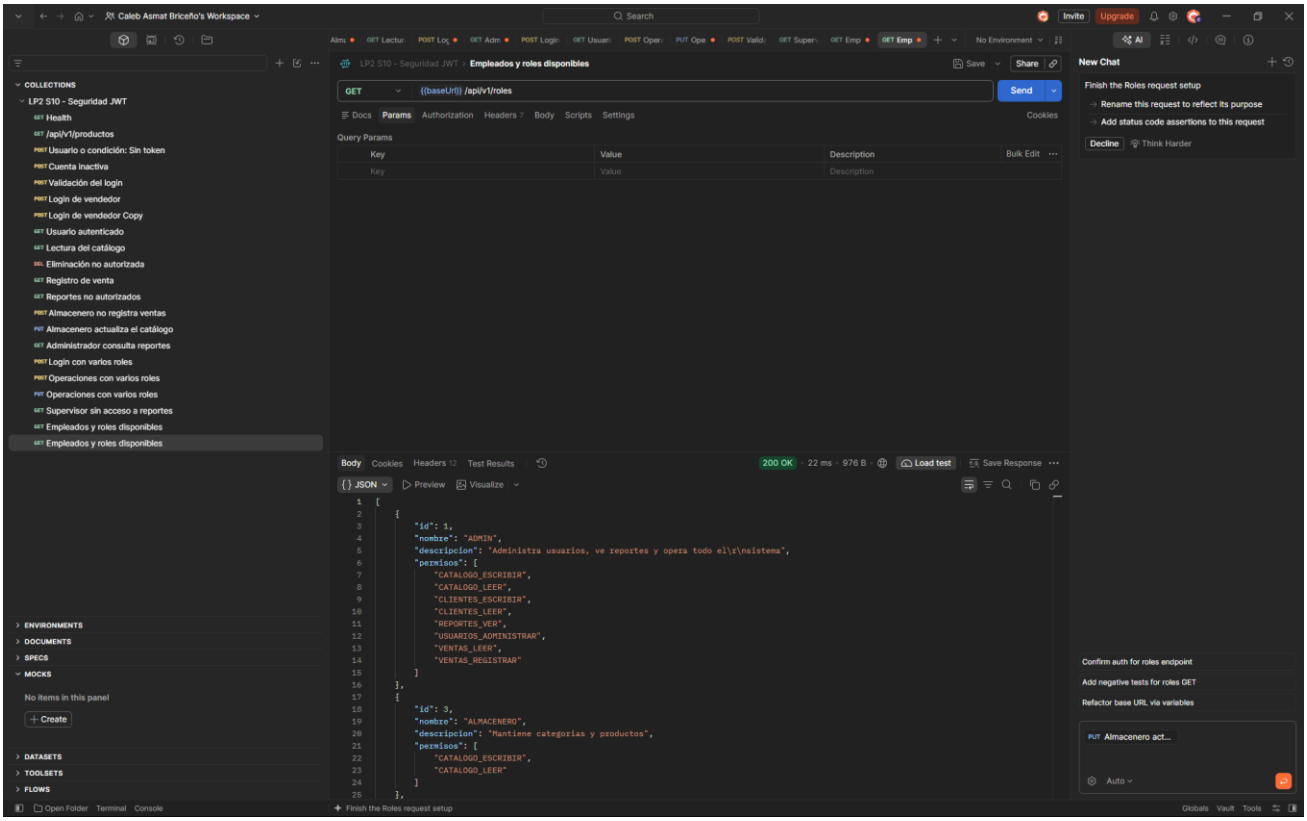
Petición: GET /api/v1/empleados y GET /api/v1/roles
Base: {{baseUrl}} = http://localhost:8080

Resultado esperado: 200 en ambas consultas; María aparece con tieneUsuario false.

Resultado obtenido: 200 OK en empleados y roles. María Huamán Torres figura con id 6 y tieneUsuario false antes del alta.

Estado: Cumple
Observaciones: Ninguna.




Caleb Asmat Briceño's Workspace
Search
Invite
Upgrade
COLLECTIONS
LP2 S10 - Seguridad JWT
GET Health
GET /api/v1/productos
POST Usuario o condición: Sin token
POST Cuenta inactiva
POST Validación del login
POST Login de vendedor
POST Login de vendedor Copy
GET Usuario autenticado
GET Lectura del catálogo
DEL Eliminación no autorizada
GET Registro de venta
GET Reportes no autorizados
POST Almacenero no registra ventas
PUT Almacenero actualiza el catálogo
GET Administrador consulta reportes
POST Login con varios roles
POST Operaciones con varios roles
PUT Operaciones con varios roles
GET Supervisor sin acceso a reportes
GET Empleados y roles disponibles
GET Empleados y roles disponibles
ENVIRONMENTS
DOCUMENTS
SPECS
MOCKS
No items in this panel
Create
DATASETS
TOOLSETS
FLOWS
LP2 S10 - Seguridad JWT / Empleados y roles disponibles
Save
Share
GET
{{baseUrl}} /api/v1/roles
Send
Docs
Params
Authorization
Headers 7
Body
Scripts
Settings
Cookies
Query Params
Key
Value
Description
Bulk Edit
Body
Cookies
Headers 12
Test Results
200 OK
22 ms
976 B
Load test
Save Response
{ } JSON
Preview
Visualize
1 [
2 {
3 "id": 1,
4 "nombre": "ADMIN",
5 "descripcion": "Administra usuarios, ve reportes y opera todo el\r\nsistema",
6 "permisos": [
7 "CATALOGO_ESCRIBIR",
8 "CATALOGO_LEER",
9 "CLIENTES_ESCRIBIR",
10 "CLIENTES_LEER",
11 "REPORTES_VER",
12 "USUARIOS_ADMINISTRAR",
13 "VENTAS_LEER",
14 "VENTAS_REGISTRAR"
15]
16 },
17 {
18 "id": 3,
19 "nombre": "ALMACENERO",
20 "descripcion": "Mantiene categorías y productos",
21 "permisos": [
22 "CATALOGO_ESCRIBIR",
23 "CATALOGO_LEER"
24]
25 },
AI
New Chat
Finish the Roles request setup
Rename this request to reflect its purpose
Add status code assertions to this request
Decline
Think Harder
Confirm auth for roles endpoint
Add negative tests for roles GET
Refactor base URL via variables
PUT Almacenero act...
Auto
Open Folder
Terminal
Console
Finish the Roles request setup
Globals
Vault
Tools

Prueba 20 Alta de usuario para María

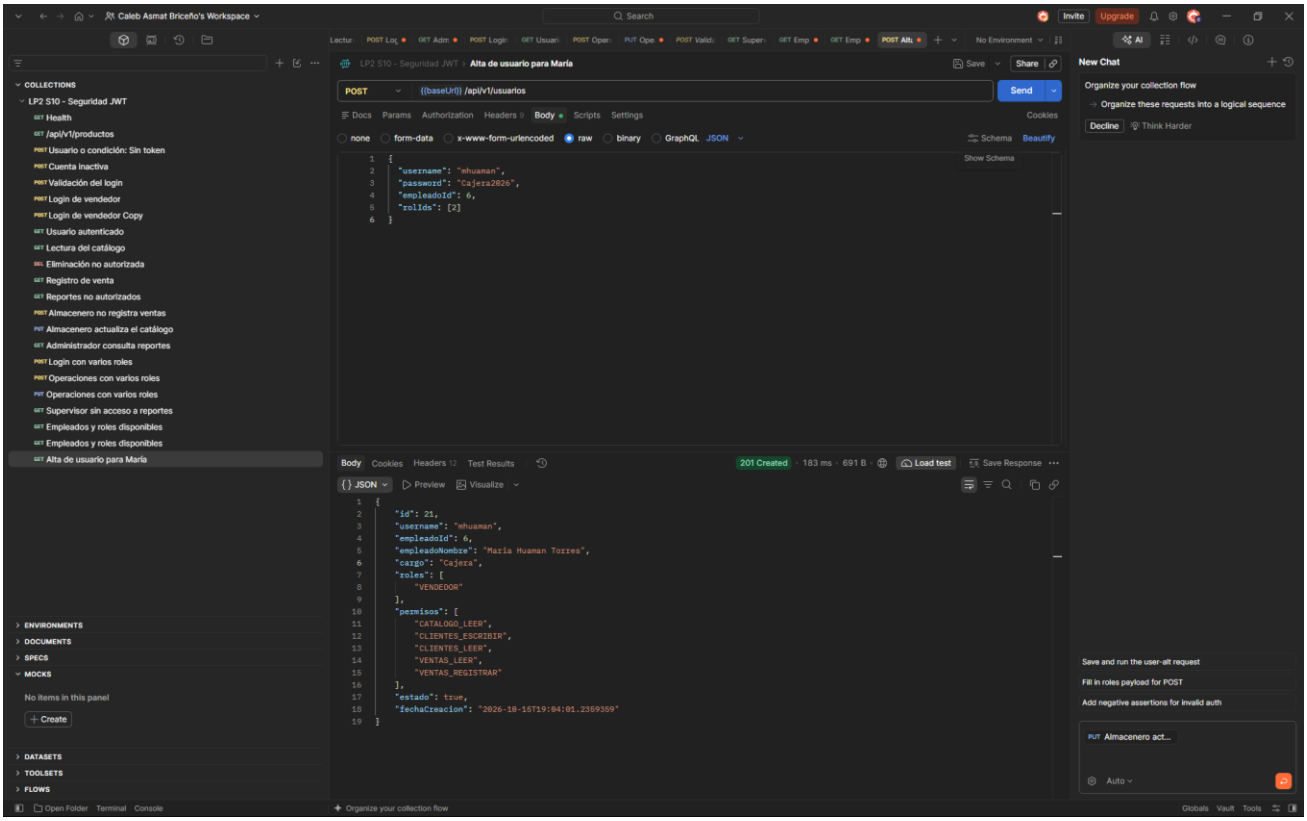
Usuario o condición: admin

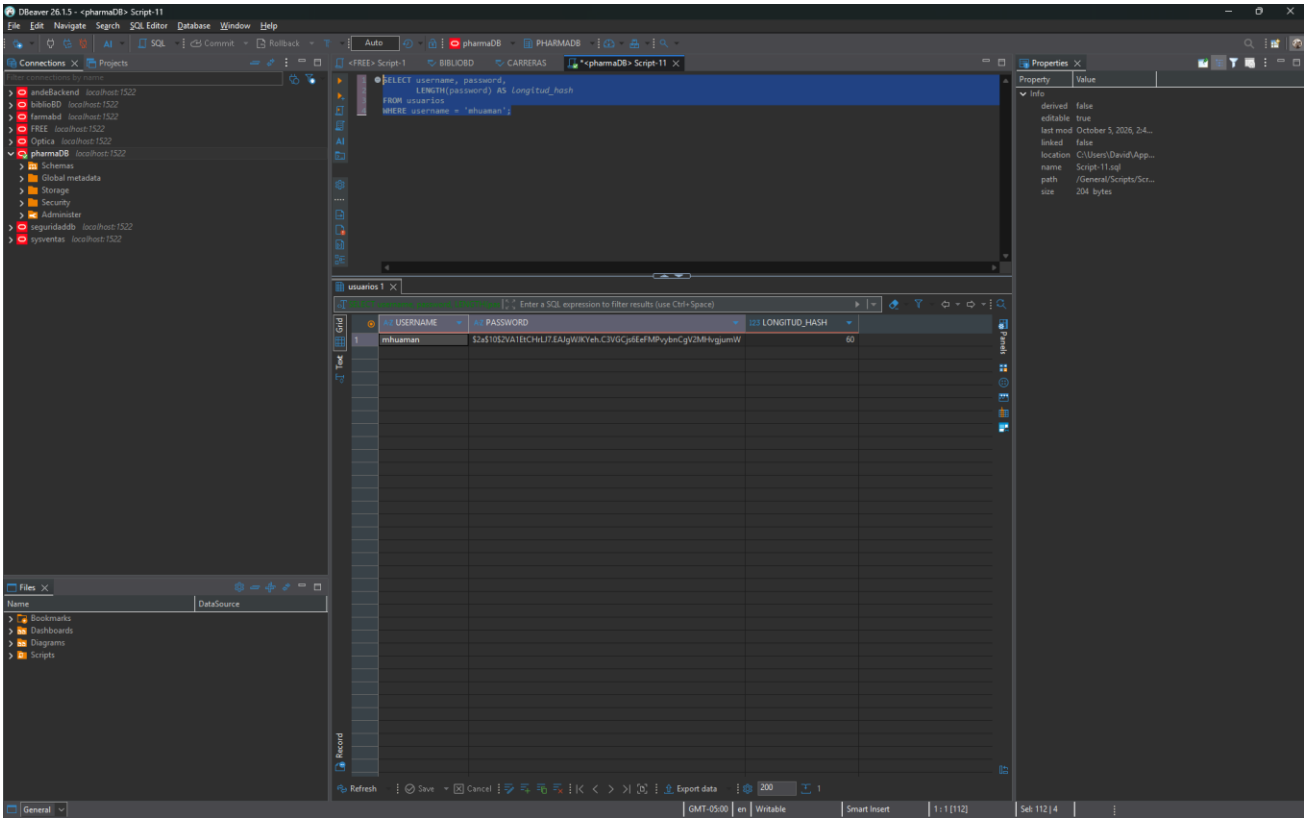
Petición: POST /api/v1/usuarios
Base: {{baseUrl}} = http://localhost:8080

Resultado esperado: 201; usuario mhuaman con rol VENDEDOR, sin contraseña ni hash en la respuesta.

Resultado obtenido: 201 Created. Se creó mhuaman con id 21, empleadoId 6 y rol VENDEDOR, sin contraseña ni hash en la respuesta. Oracle muestra un hash BCrypt de 60 caracteres.

Estado: Cumple
Observaciones: La captura de Oracle acredita el hash y su longitud. El rol VENDEDOR se observa en la respuesta del alta.




DBeaver 26.1.5 - <pharmaDB> Script-11
File Edit Navigate Search SQL Editor Database Window Help
Connections Projects
andleBackend localhost:1522
biblioBD localhost:1522
farmabd localhost:1522
FREE localhost:1522
Optica localhost:1522
pharmaDB localhost:1522
Schemas
Global metadata
Storage
Security
Administer
seguridaddb localhost:1522
tysventas localhost:1522
Files
Name
DataSource
Bookmarks
Dashboards
Diagrams
Scripts
<FREE> Script-1
BIBLIOBD
CARRERAS
*<pharmaDB> Script-11
SELECT username, password,
LENGTH(password) AS Longitud_hash
FROM usuarios
WHERE username = 'mhuaman';
usuarios 1
Enter a SQL expression to filter results (use Ctrl+Space)
USERNAME
PASSWORD
LONGITUD_HASH
mhuaman
$2a$10$2VA1EtCHrLJ7.EAJgWJKYeh.C3VGCjs6EeFMPvybnCgV2MHvgjumW
60
Refresh
Save
Cancel
Export data
Properties
Property
Value
info
derived false
editable true
last mod October 5, 2026, 2:4...
linked false
location C:\Users\David\App...
name Script-11.sql
path /General/Scripts/Scr...
size 204 bytes
General
GMT-05:00
en
Writable
Smart Insert
1 : 1 [112]
Sel: 112 | 4

Prueba 21 Un empleado no tiene dos cuentas

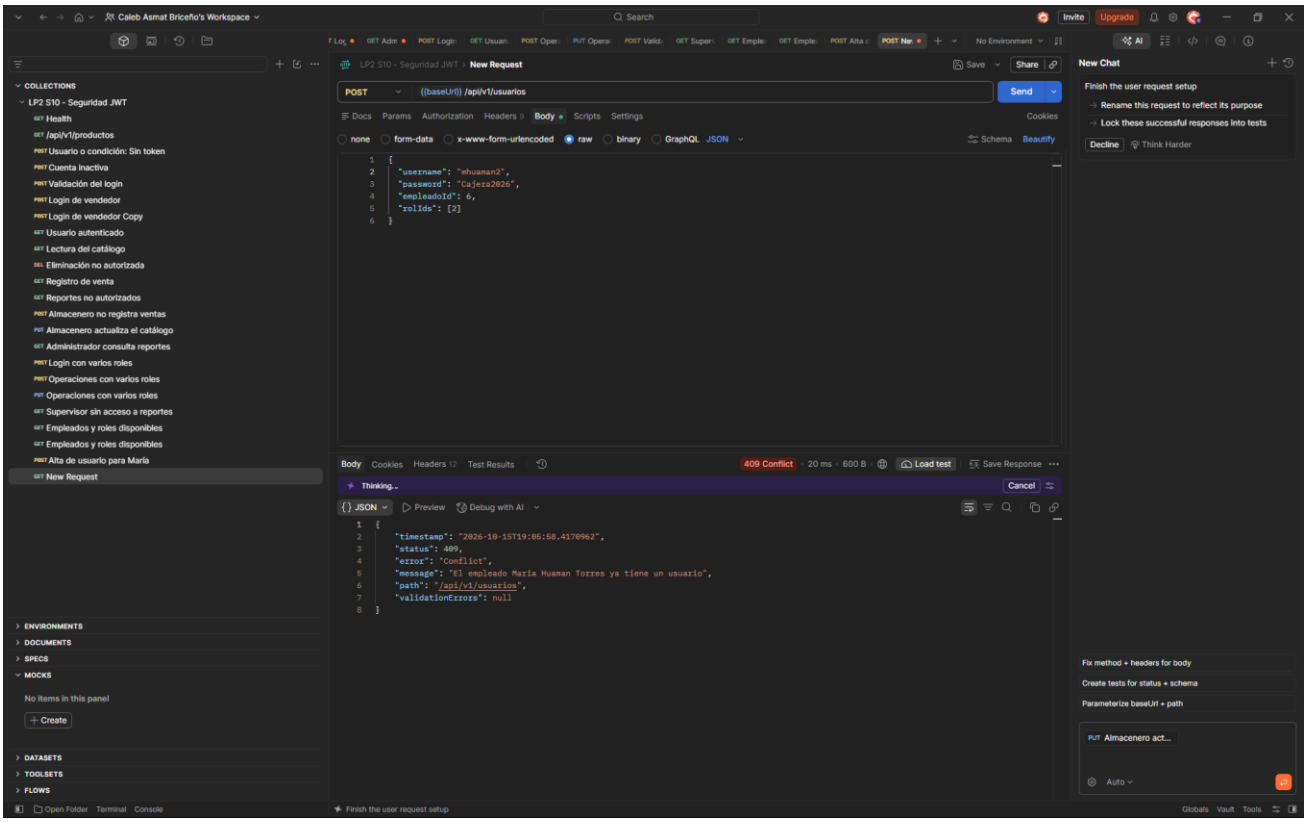
Usuario o condición: admin

Petición: POST /api/v1/usuarios
Base: {{baseUrl}} = http://localhost:8080

Resultado esperado: 409; el empleado ya tiene un usuario.

Resultado obtenido: 409 Conflict. Al intentar crear mhuaman2 para el empleado 6 se respondió El empleado Maria Huaman Torres ya tiene un usuario.

Estado: Cumple
Observaciones: Ninguna.



Prueba 22 Rol inexistente

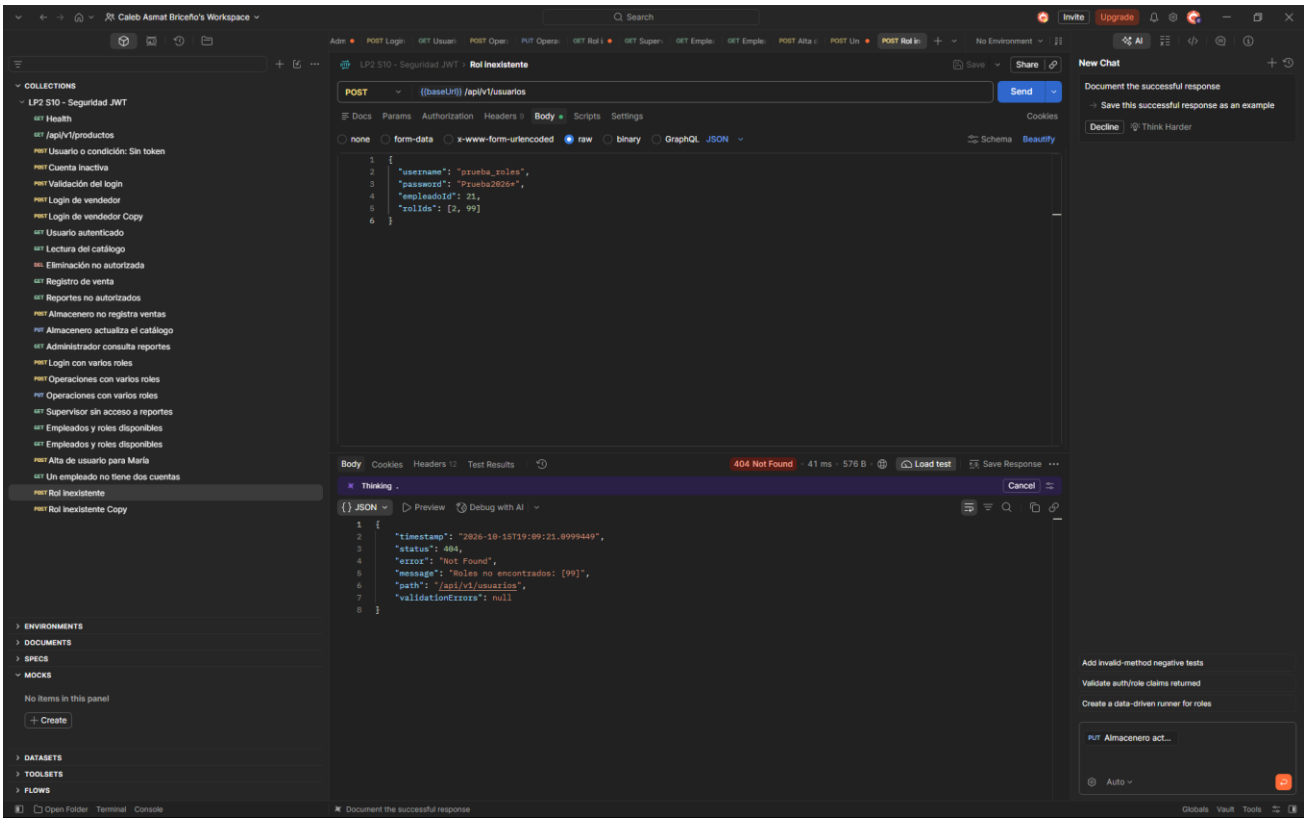
Usuario o condición: admin

Petición: POST /api/v1/usuarios
Base: {{baseUrl}} = http://localhost:8080

Resultado esperado: 404; Roles no encontrados con el ID 99.

Resultado obtenido: 404 Not Found. La solicitud para prueba_roles con empleadoId 21 y rolIds 2 y 99 devolvió Roles no encontrados: [99].

Estado: Cumple
Observaciones: Ninguna.



Prueba 23 Token alterado

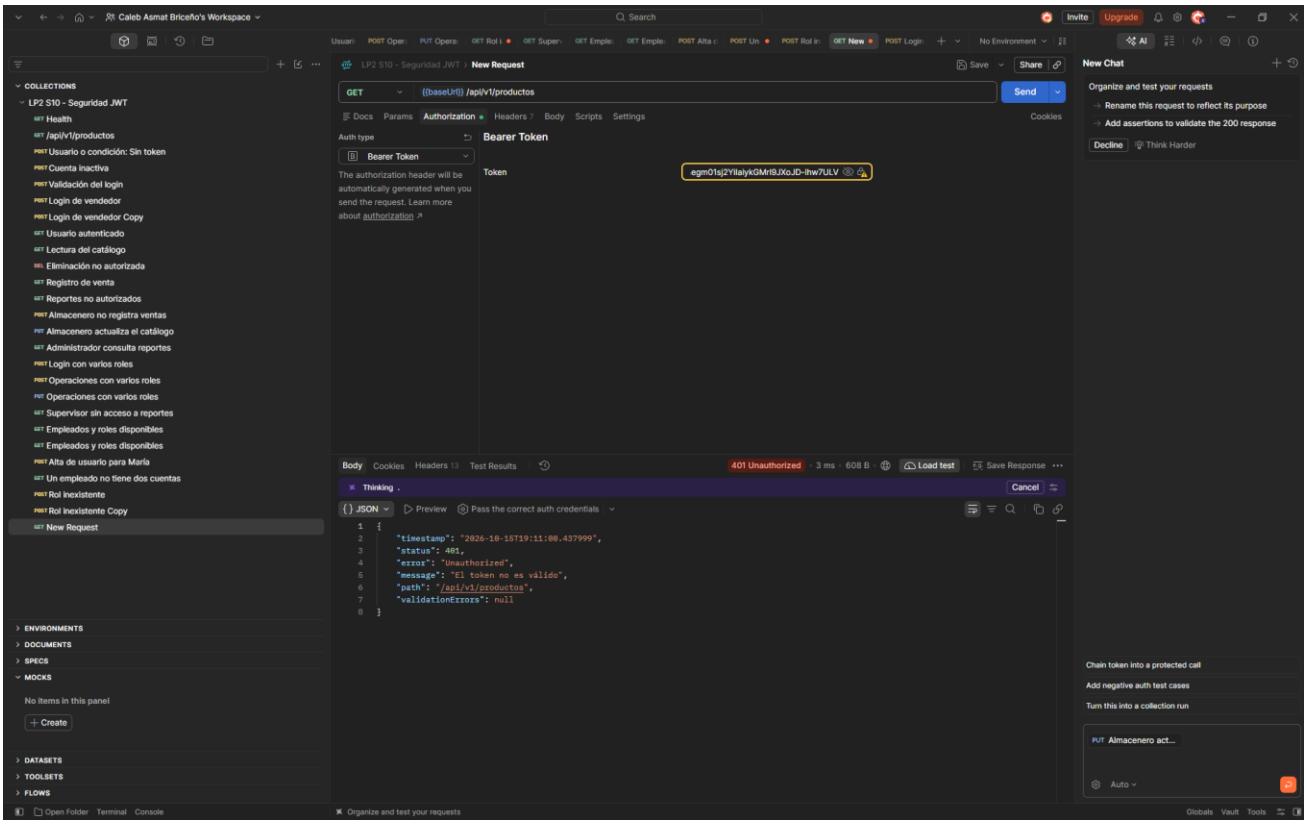
Usuario o condición: vendedor con token modificado

Petición: GET /api/v1/productos
Base: {{baseUrl}} = http://localhost:8080

Resultado esperado: 401; El token no es válido.

Resultado obtenido: 401 Unauthorized. La petición con token modificado devolvió El token no es válido.

Estado: Cumple
Observaciones: Ninguna.



Prueba 24 Token expirado

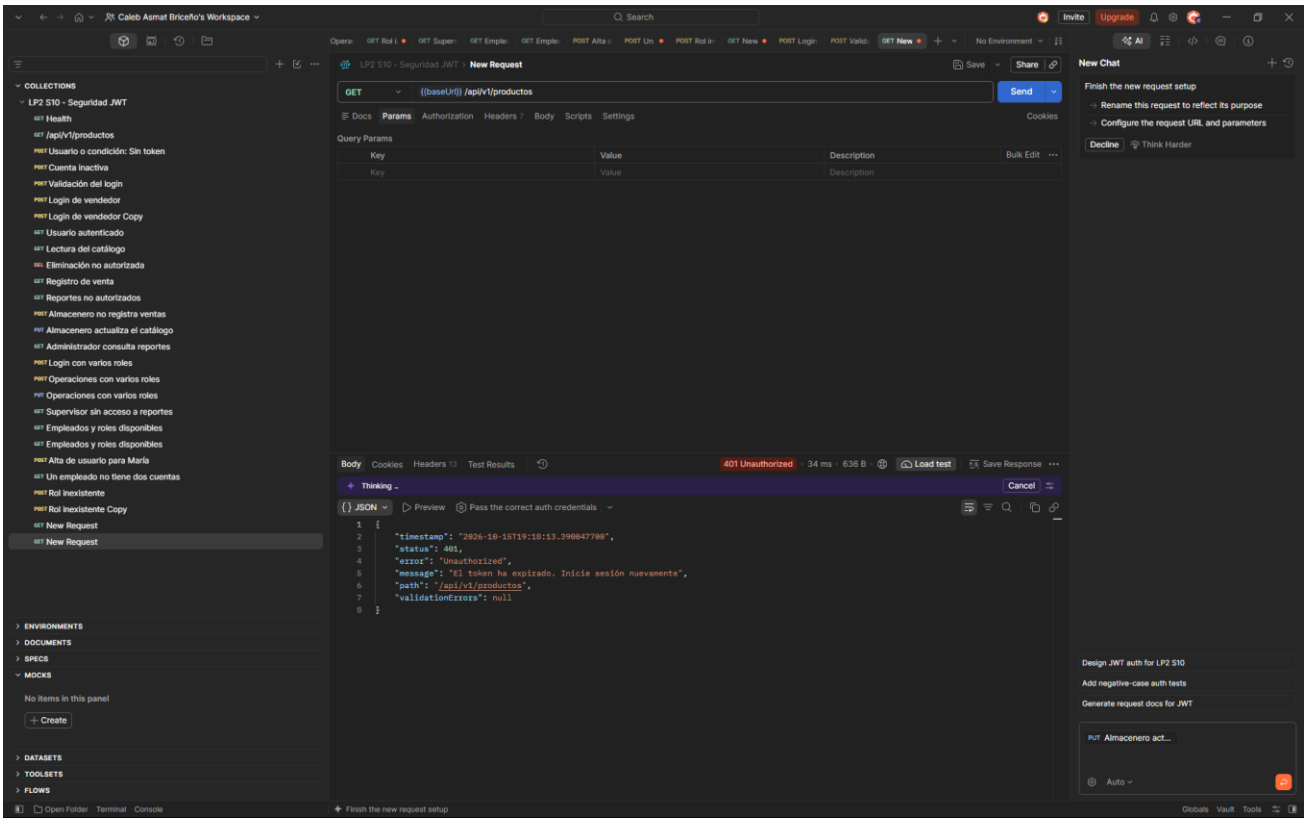
Usuario o condición: vendedor con token vencido

Petición: GET /api/v1/productos
Base: {{baseUrl}} = http://localhost:8080

Resultado esperado: 401; El token ha expirado. Inicie sesión nuevamente.

Resultado obtenido: 401 Unauthorized. La petición con token vencido devolvió El token ha expirado. Inicie sesión nuevamente.

Estado: Cumple
Observaciones: Ninguna.



Anexo de cuerpos JSON y consultas

VENTA

```
{
  "clienteId": 1,
  "detalles": [{"productoId": 1, "cantidad": 1}]
}
```

PRODUCTO

```
{
  "nombre": "Nombre actual del producto",
  "precio": 10.50,
  "stock": 20,
  "estado": true,
  "categoriaId": 1
}
```

ALTA

```
{
  "username": "mhuaman",
  "password": "Cajera2026",
  "empleadoId": 6,
  "rolIds": [2]
}
```

Evidencia de BCrypt y roles

```
SELECT username, password, LENGTH(password) AS longitud_hash
FROM usuarios WHERE username = 'mhuaman';

SELECT ur.usuario_id, ur.rol_id, u.username, r.nombre
FROM usuario_roles ur
JOIN usuarios u ON u.id = ur.usuario_id
JOIN roles r ON r.id = ur.rol_id
WHERE u.username = 'mhuaman';
```

Anexo de preparación del caso 22 y JWT

Empleado adicional para el caso 22

```
INSERT INTO empleados
(dni, nombres, apellidos, cargo, email, estado, fecha_creacion)
VALUES
('99887766', 'Prueba', 'Roles', 'Auxiliar',
 'prueba.roles@pharmasoft.pe', true, systimestamp);
COMMIT;

SELECT id, dni, nombres, apellidos FROM empleados
WHERE dni = '99887766';
```

Script de decodificación JWT

```
if (pm.response.code === 200) {
  const token = pm.response.json().token;
  const parte = token.split(".")[1]
    .replace(/-/g, "+").replace(/_/g, "/");
  const payload = JSON.parse(atob(parte));
  console.log("Payload JWT:", payload);
  console.log("Duración:", payload.exp - payload.iat);
  pm.test("Duración de 3600 segundos", function () {
    pm.expect(payload.exp - payload.iat).to.eql(3600);
  });
}
```

Evidencias complementarias de la entrega

Pruebas unitarias de seguridad

```
.\mvnw.cmd test "-Dtest=JwtServiceTest,PermisosPorRolTest"
```

